

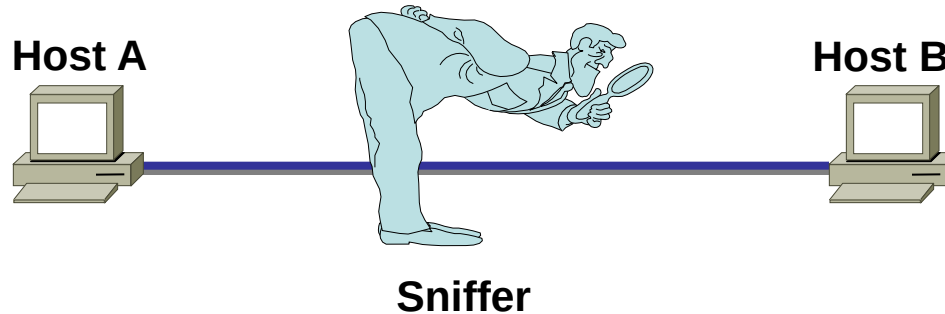
3. Securitatea la nivelul rețelei locale (LAN)



De ce securitate la nivel LAN?

- 90% din porturile de rețea ale companiilor sunt deschise
- În mod obișnuit, orice laptop se poate conecta pe unul din aceste porturi și obține acces în rețea
- 70% din atacuri vin din interiorul organizației
- Atacuri specifice:
 - Sniffing
 - DHCP Starvation
 - Rogue DHCP Server
 - ARP Poisoning
 - ...

Sniffers



- Un sniffer de pachete este un sistem a cărui placă de rețea operează în modul promiscuous și care captează pachetele transmise în rețea
- Captarea pachetelor se face în timp real
- Necesită privilegii de superuser pentru a fi rulat
- Folosit pentru:
 - diagnosticarea problemelor (inclusiv cele de securitate) apărute în cadrul rețelelor – analizor de rețea
 - jurnalizarea traficului din rețea în vederea analizei ulterioare în cazul apariției unui incident de securitate – forensics analysis
 - interceptarea parolelor sau a altor informații confidențiale – hacking tool

Sniffers - Produse

- tcpdump (<http://www.tcpdump.org>)
 - platforme Unix
 - utilitar în linie de comandă
- Wireshark (<http://www.wireshark.org/>)
 - interfață grafică
 - disponibil pe aproape toate tipurile de platforme
 - tshark (utilitar în linie de comandă)
- ngrep (<http://ngrep.sourceforge.net/>)
 - regular expressions pentru căutarea în pachete
- Librari (API) pentru captarea de pachete (pcap):
 - libpcap / WinPcap (C/C++)
 - JpCap (Java)

tcpdump

- **Sintaxa:**

tcpdump [options] [filter expression]

- **Optiuni uzuale:**

- i <n>: specifica interfata pe care se face captarea pachetelor
- a: activeaza conversia adreselor IP in nume
- n: dezactiveaza conversia adreselor IP in nume
- s 0: analizeaza intregul pachet
- A: tipareste continutul pachetului in format ASCII
- w <filename>: salveaza pachetele captate intr-un fisier
- r <filename>: citeste pachetele dintr-un fisier

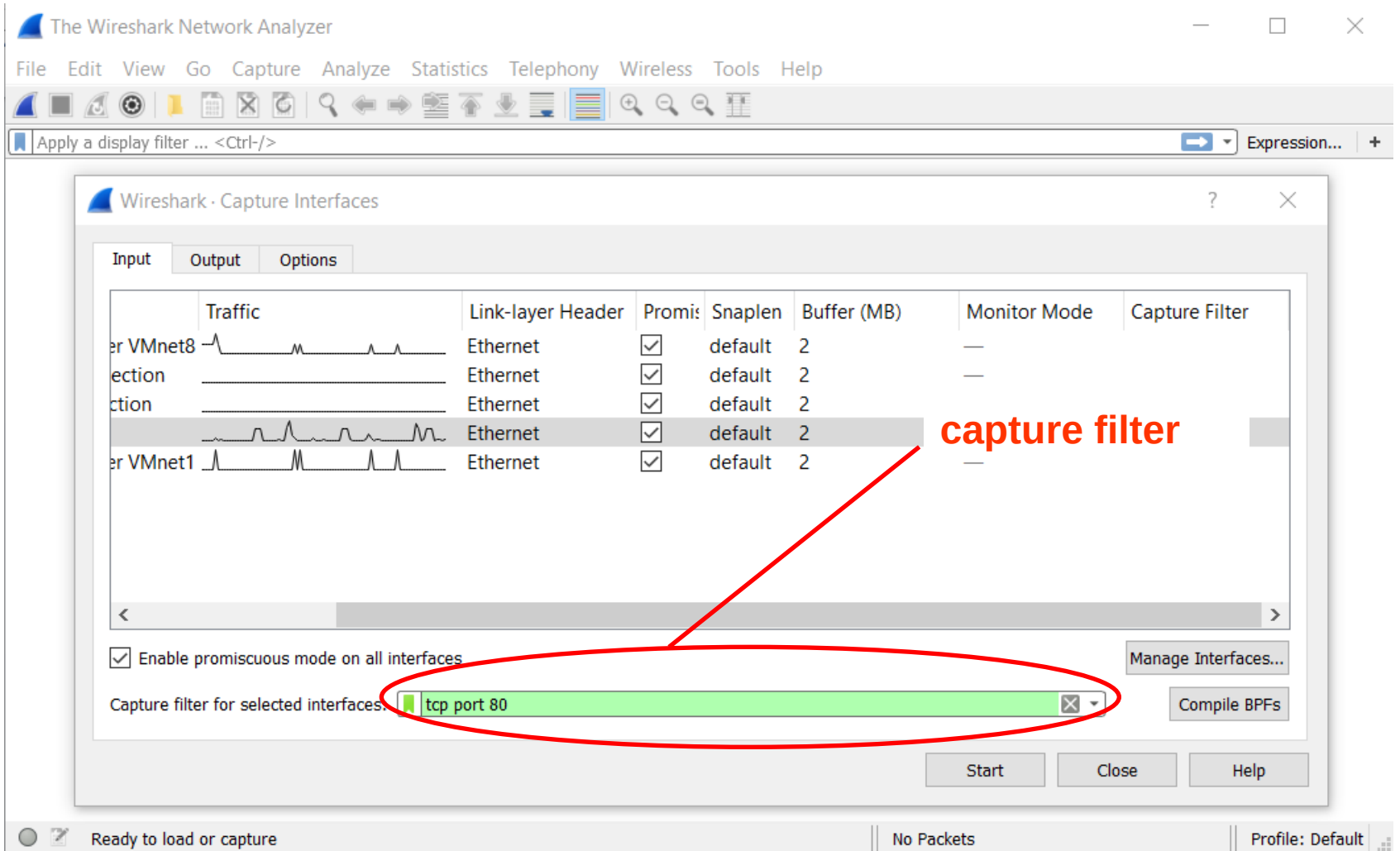
tcpdump (cont.)

- Filtrare dupa protocol
 - “icmp”
 - “udp”
 - “tcp”
- Filtrare dupa adresa
 - “dst host <name/IP>”
 - “src host <name/IP>”
 - “host <name/IP>”
- Filtrare dupa port
 - “dst port <number>”
 - “src port <number>”
 - “port <number>”
- Combinarea filtrelor
 - *and* (&&)
 - *or* (||)
 - *not* (!)

tcpdump (cont.)

- **Afişare interfețe de rețea**
tcpdump -D
- **Captare trafic de rețea de la o anumită interfață**
tcpdump -i eth0
- **Captare trafic după adresa IP**
tcpdump host 192.160.0.10
- **Captare trafic după port**
tcpdump port 22
- **Captare trafic după protocol**
tcpdump icmp
tcpdump tcp port 443
- **Afişare pachete captate în ASCII / HEX**
tcpdump -A tcp port 80
tcpdump -X tcp port 80
- **Dezactivare conversie adrese în nume**
tcpdump -n
- **Salvare pachete captate într-un fișier**
tcpdump port 80 -w capture_file
- **Citire pachete din fișier**
tcpdump -r capture_file

Wireshark



Wireshark (cont.)

*Local Area Connection

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.dstport == 443

No.	Time	Source	Destination	Protocol	Length	Info
3	4.949917	LcfcHefe_69:70:7c	SmcNetwo_8e:9f:bb	ARP	42	Who has 192.168.2.1? Tell 192.168.2.101
4	4.950811	SmcNetwo_8e:9f:bb	LcfcHefe_69:70:7c	ARP	60	192.168.2.1 is at 00:13:f7:8e:9f:bb
5	7.593496	192.168.2.101	216.58.210.3	IPv4	1314	Fragmented IP protocol (proto=UDP 17, o...
6	7.593511	192.168.2.101	216.58.210.3	QUIC	112	Client Hello, PKN: 1, CID: 507998659195...
7	7.595000	192.168.2.101	192.168.2.1	DNS	76	Standard query 0x7b1a A en.wikipedia.org
8	7.628392	216.58.210.3	192.168.2.101	QUIC	1392	Payload (Encrypted), PKN: 1

> Frame 23: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface 0

> Ethernet II, Src: LcfcHefe_69:70:7c (28:d2:44:69:70:7c), Dst: SmcNetwo_8e:9f:bb (00:13:f7:8e:9f:bb)

> Internet Protocol Version 4, Src: 192.168.2.101, Dst: 91.198.174.192

> Transmission Control Protocol, Src Port: 25816, Dst Port: 443, Seq: 0, Len: 0

display filter

Offset	Hex	ASCII
0000	00 13 f7 8e 9f bb 28 d2 44 69 70 7c 08 00 45 00	(. Dip ..E.
0010	00 34 72 99 40 00 80 06 00 00 c0 a8 02 65 5b c6	.4r.@... ..e[.
0020	ae c0 64 d8 01 bb 10 f7 8d 17 00 00 00 00 80 02	..d.....
0030	ff f0 cd ba 00 00 02 04 04 ec 01 03 03 08 01 01	
0040	04 02	..

wireshark_AA685010-C3F2-469E-BDC7-EC6D16663EA7_20170705093326_a05356

Packets: 1369 · Displayed: 1369 (100.0%)

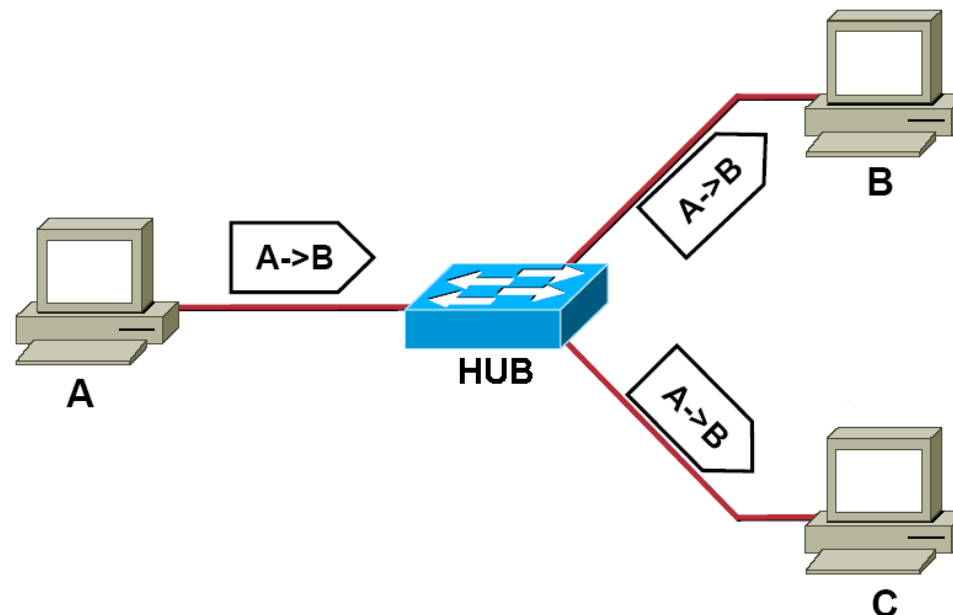
Profile: Default

TShark

- **Terminal-based Wireshark**
- **Sintaxă similară cu tcpdump**
- **Suportă filtre de captare (BFP) și filtre de afișare**
 - # tshark -i any -w traffic.pcap**
 - # tshark -i eth0 -f "host 192.168.1.100 and port 80"**
 - # tshark -i eth0 -Y "tcp.port == 8080 and http.request"**

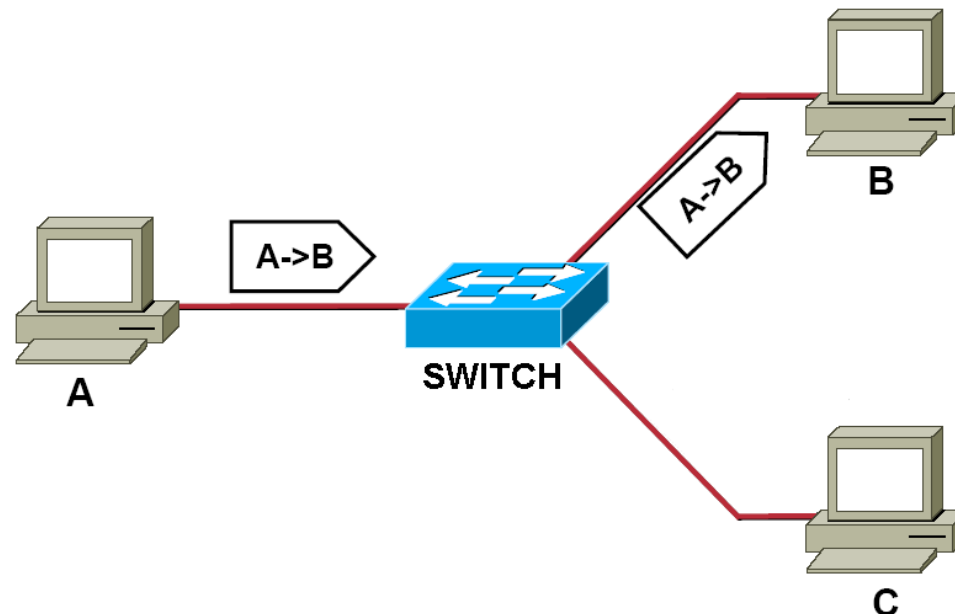
Sniffing pasiv

- Folosit pentru a intercepta traficul în rețele bazate pe HUB-uri
 - traficul de pe un port este forwardat către toate celelalte porturile
- Este suficient doar să se asculte pentru a capta toate pachetele din rețea
 - nu se intervine cu nimic asupra rețelei
 - atacul nu poate fi detectat



Sniffing activ

- Folosit pentru a intercepta traficul în rețele bazate pe SWITCH-uri
 - traficul de pe un port este forwardat numai către portul destinație corespunzător
- Pentru a putea capta pachetele din rețea trebuie să se intervină asupra rețelei
- Atacuri posibile
 - inundarea switch-ului (MAC Flooding)
 - furarea portului (Port Stealing)



Adrese MAC

48 Bit Hexadecimal Number Creates Unique Layer Two Address

1234.5678.9ABC

First 24 bits = Manufacture Code
Assigned by IEEE

0000.0cXX.XXXX

Second 24 bits = Specific Interface,
Assigned by Manufacture

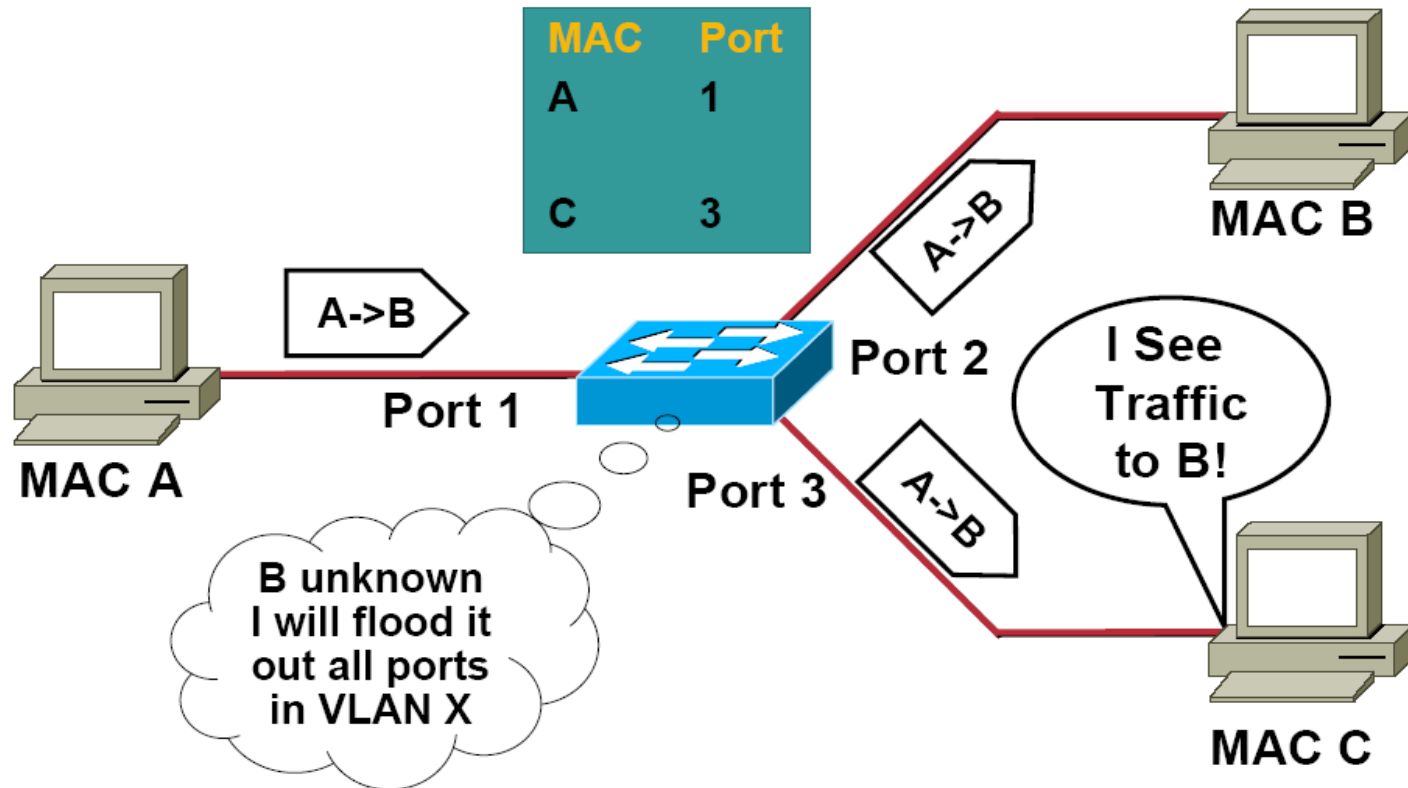
0000.0cXX.XXXX

All F's = Broadcast

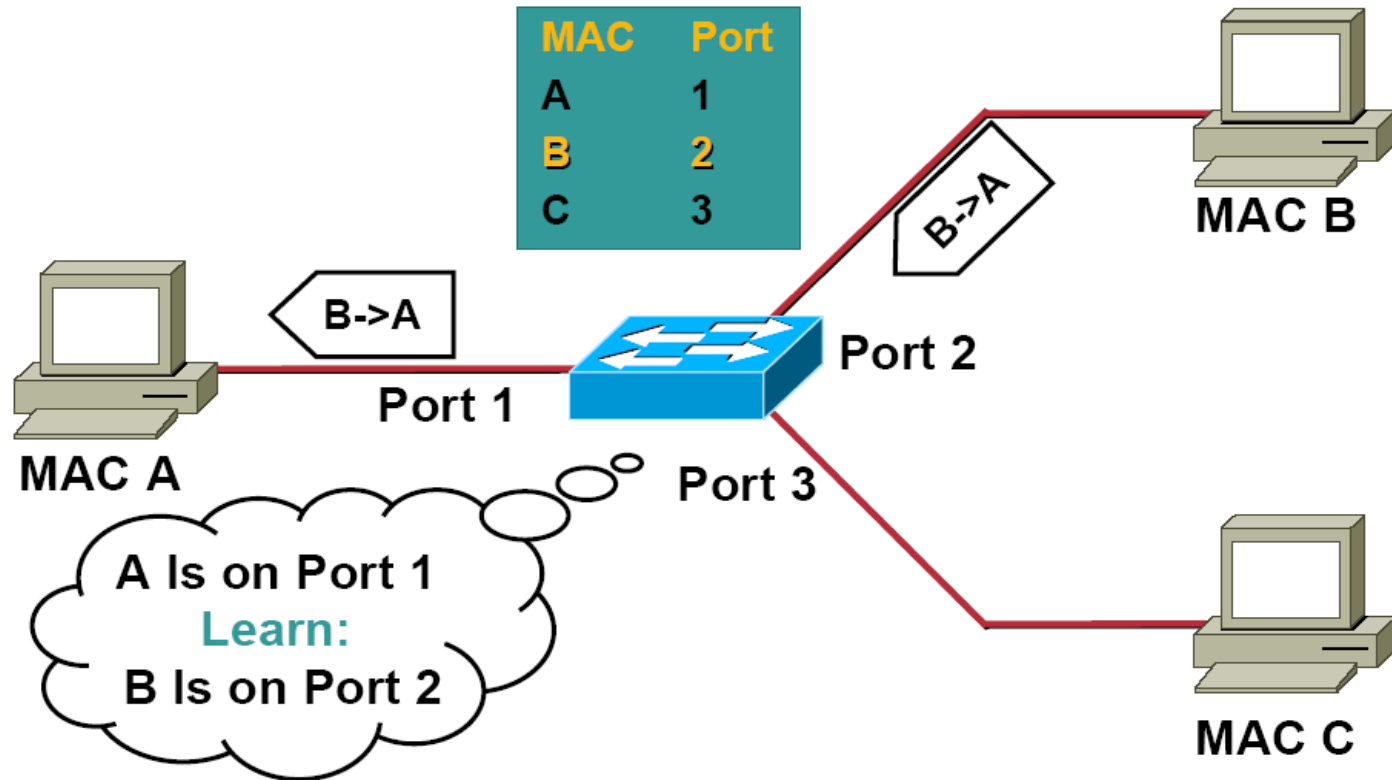
FFFF.FFFF.FFFF

- Pentru a-și îndeplini rolul și a optimiza distribuția traficului, switch-urile “învață” aceste adrese, memorandu-le într-o așa numită tabelă CAM (Content Addressable Memory)
- Tabela CAM a unui switch dispune de o zonă limitată de memorie (parametru important al unui switch)

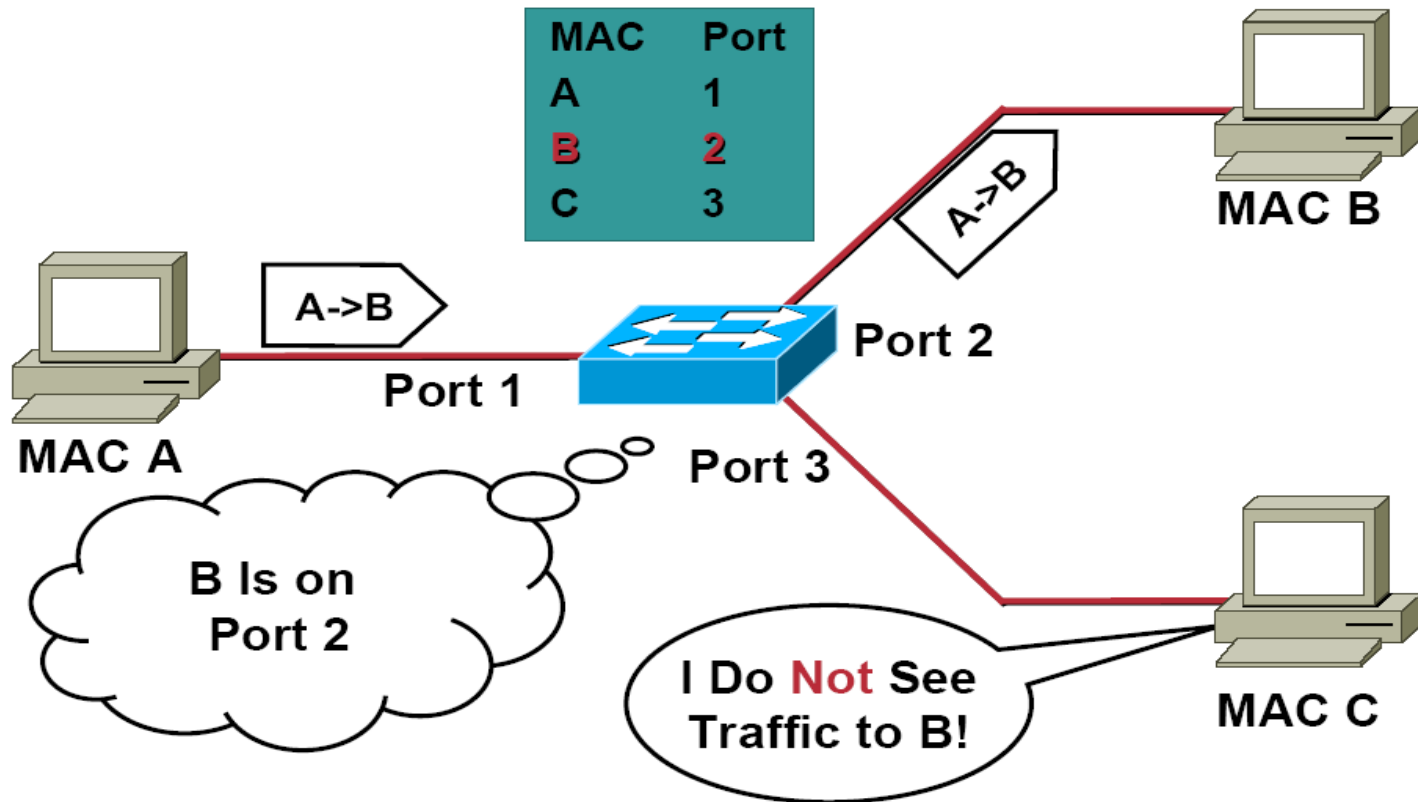
Funcționarea normală a unui switch



Funcționarea normală a unui switch (cont.)



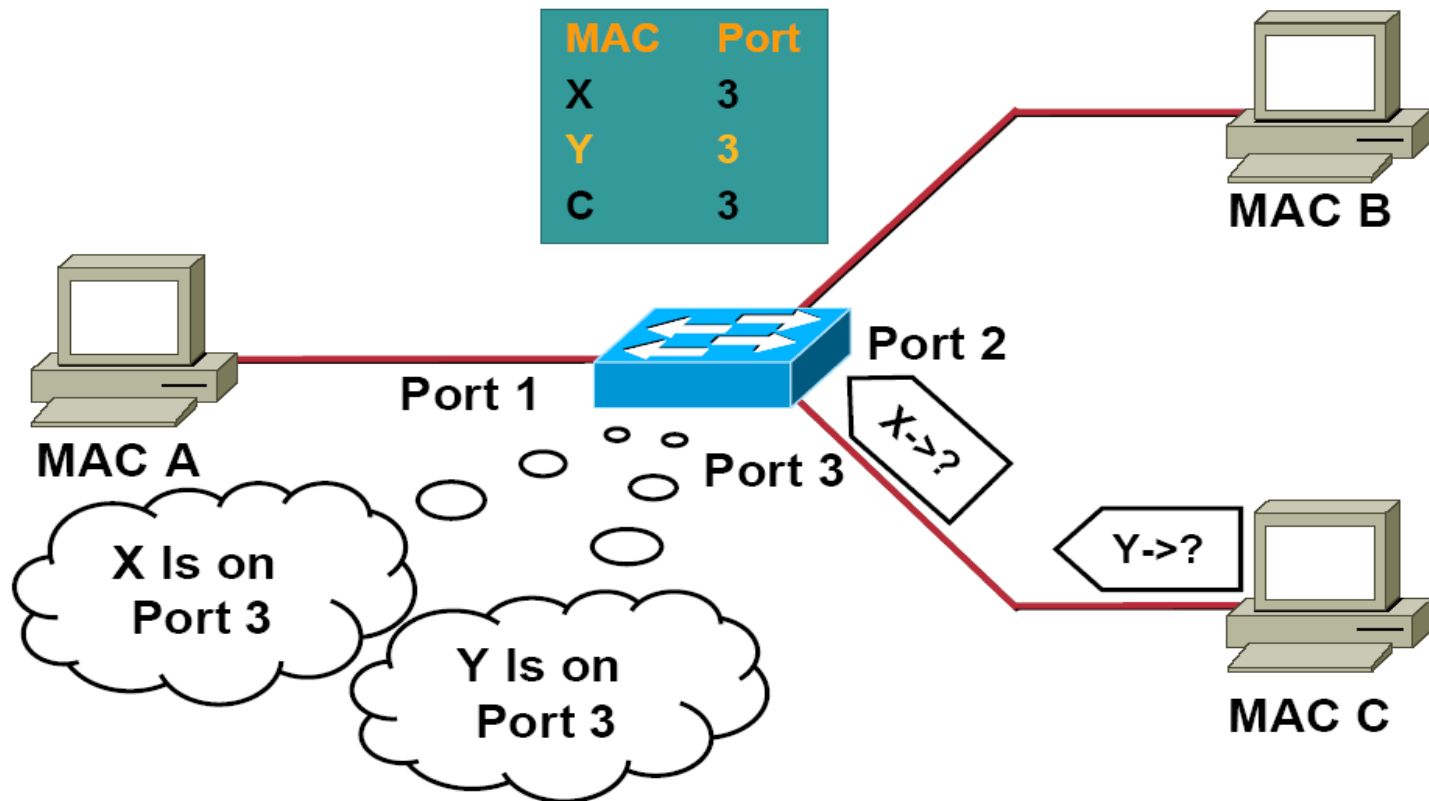
Funcționarea normală a unui switch (cont.)



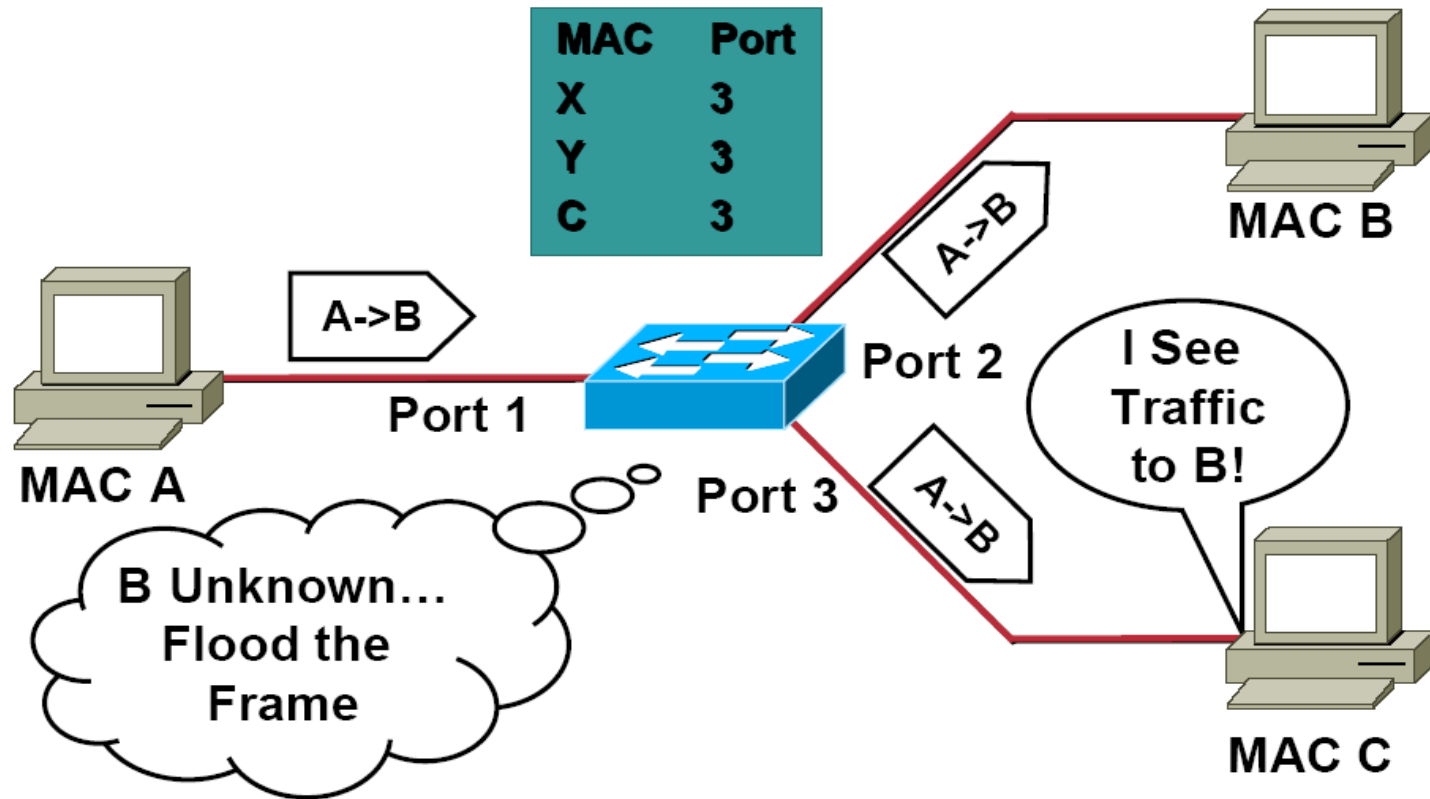
MAC Flooding

- Până în Mai 1999, atacul era considerat ca fiind posibil numai din punct de vedere teoretic
- În Mai 1999, Ian Vitek demonstrează printr-un program scris în Perl – *macof* – că atacul este fezabil
 - atacul se bazează pe capacitatea limitată a memoriei alocată tablei CAM dintr-un switch (valori uzuale: 32K, 64K, 128K)
- Programul a fost ulterior portat în C, sub numele de *dsniff* (<http://monkey.org/~dugsong/dsniff/>)
 - colecție de unelte pentru penetration testing
 - sniffing pasiv: dsniff, filesnarf, mailsnarf, msgsnarf, urlsnarf, webspay
 - sniffing activ: arpspoof, dnsspoof, macof
 - atacuri de tip monkey-in-the-middle: sshmitm, webmitm

MAC Flooding (cont.)



MAC Flooding (cont.)

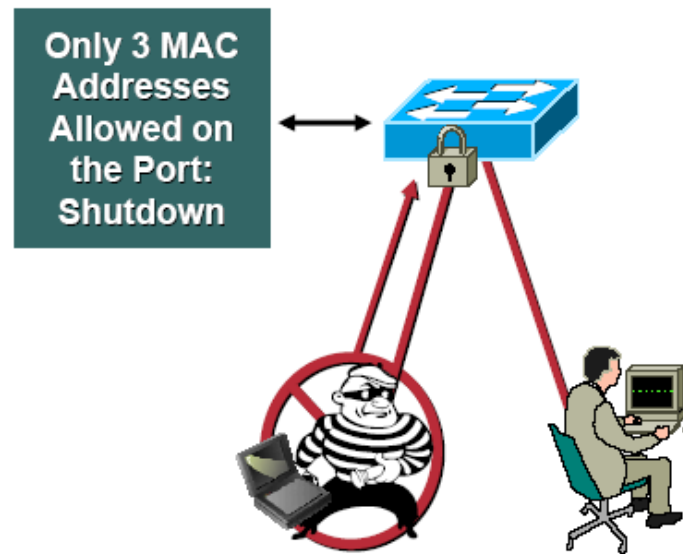
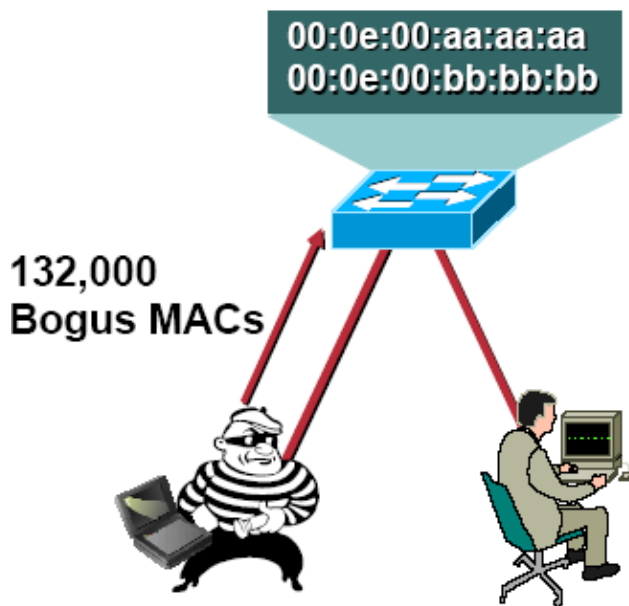


Port Stealing

- Switch-urile asociază adrese MAC cu porturi fizice de comunicație
 - maparea se realizează în urma examinării adresei MAC sursă a cadrelor recepționate
- Atacul de tip “port stealing” constă în inundarea rețelei cu cadre, având:
 - Adresa MAC Destinație egală cu adresa atacatorului
 - **Adresa MAC Sursă** egală cu adresa victimei (e.g., default gateway)
- Astfel, switch-ul va asocia adresa MAC a victimei cu portul la care se află conectat atacatorul
 - atacatorul va putea astfel intercepta toate cadrele având ca destinație adresa victimei
- Cum retransmitem cadrele înapoi către victimă?
 - atacatorul trimite request-uri ARP pentru a afla adresa IP a victimei
 - victima răspunde, switch-ul vede cadrul și actualizează numărul de port
 - atacatorul trimite cadrele interceptate anterior către victimă
- Unele:
 - Ettercap (<http://ettercap.sourceforge.net/>)

MAC Flooding / Port Stealing - Contramăsuri

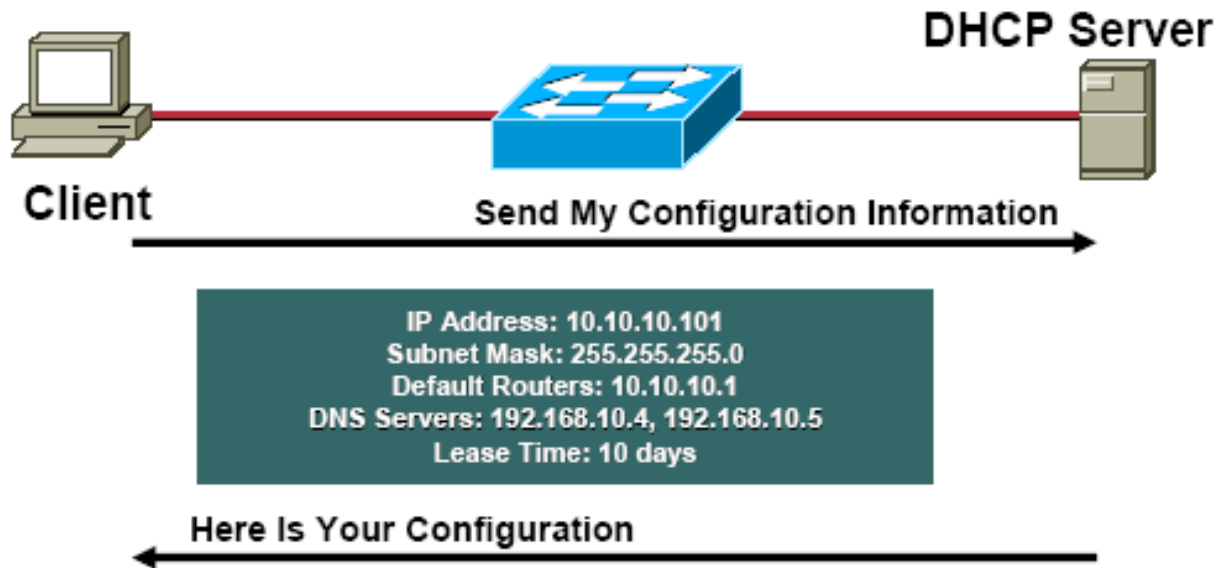
- Limitarea numărului maxim de adrese MAC învățate pe un port de către switch



Mecanismul "Port Security"

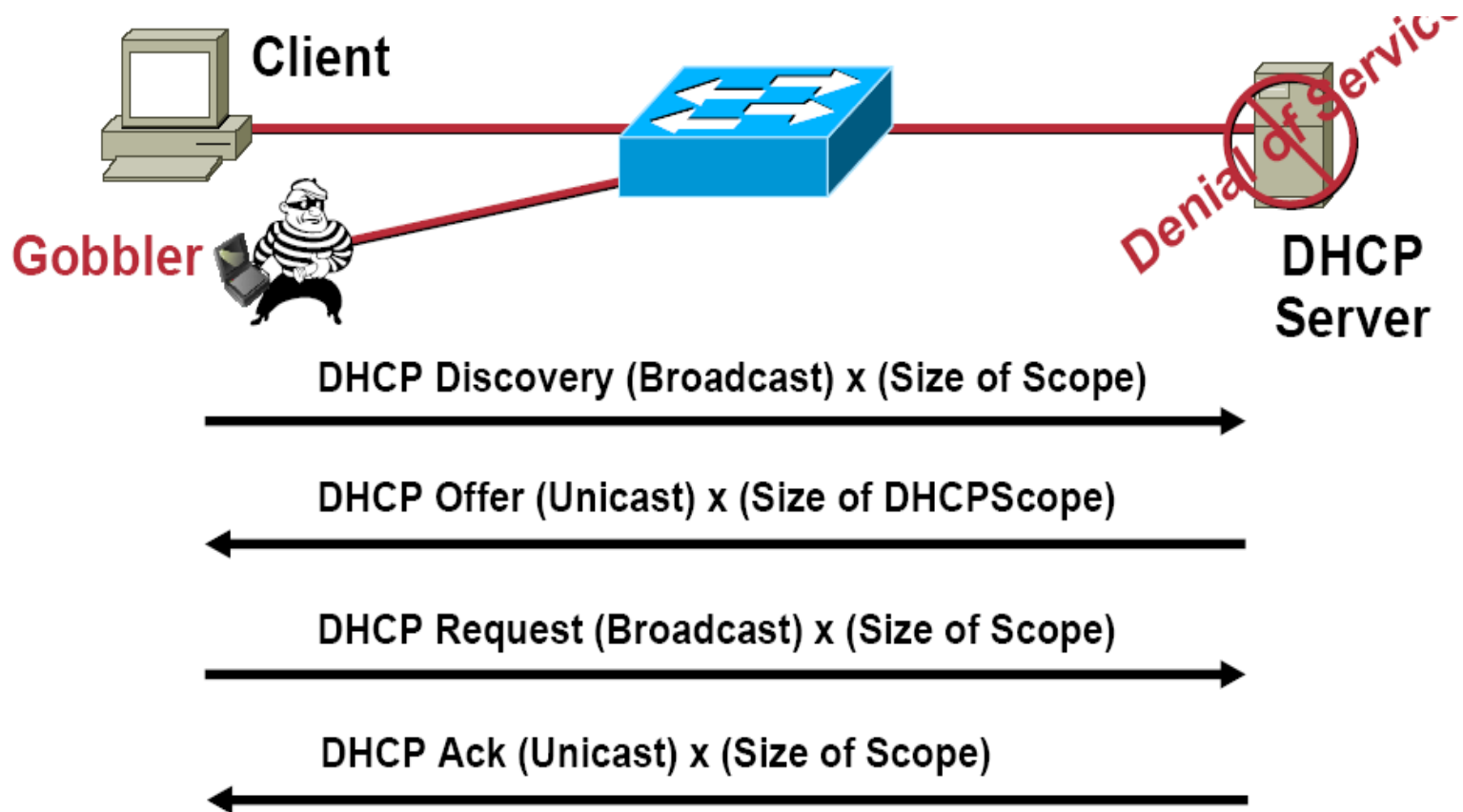
- limitarea numărului de adrese MAC permise pe un port, blocarea portului în caz de depășire, transmiterea unei trape SNMP

Protocolul DHCP



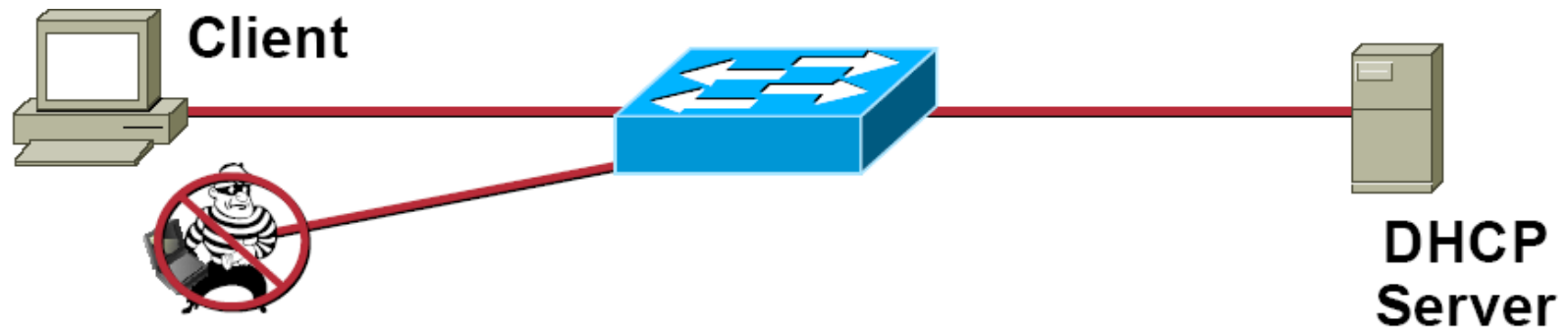
- Administratorul configurează un spațiu de adrese IP alocabil dinamic
- Server-ul alocă dinamic o adresa IP, la cerere
- Adresa este alocată pentru o perioadă de timp
- În campul “Options” sunt furnizate informații suplimentare

Atacul de tip DHCP Starvation



- Atacatorul încearcă să închirieze toate adresele IP disponibile prin DHCP
- Atac de tip Denial of Service (DoS)

DHCP Starvation - Contramăsuri



- De fiecare dată când atacatorul face o cerere DHCP utilizează o adresă MAC diferită
- Mecanismul “Port Security” restricționează numărul maxim de adrese MAC acceptate pe un port
- Atacatorul nu va putea obține un număr de adrese IP mai mare decât numărul maxim de adrese MAC acceptate pe acel port

Atacul de tip Rogue DHCP Server



DHCP Discovery (Broadcast)



2 DHCP Offers (Unicast) (1 from Rogue, 1 genuine)



DHCP Request (Broadcast) to 1st offer



DHCP Ack (Unicast) from Rogue Sever



Atacul de tip Rogue DHCP Server (cont.)

- Ce poate să facă atacatorul atunci când devine server DHCP?

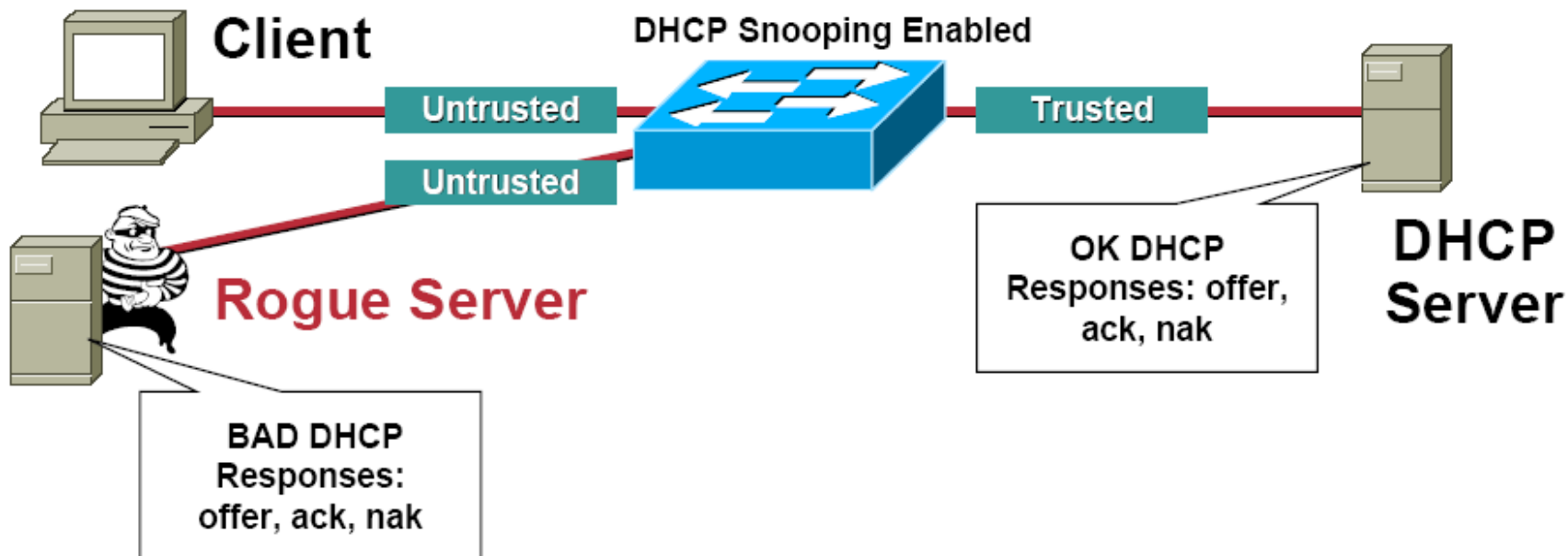
```
IP Address: 10.10.10.101
Subnet Mask: 255.255.255.0
Default Routers: 10.10.10.1
DNS Servers: 192.168.10.4, 192.168.10.5
Lease Time: 10 days
```

Here is Your Configuration



- Furnizează informații incorecte, cum ar fi:
 - Default Gateway – Atacatorul este gateway
 - DNS Server – Atacatorul este server DNS
 - Adresa IP – Alocată incorect (atac de tip DoS)

Rogue DHCP Server - Contramăsuri

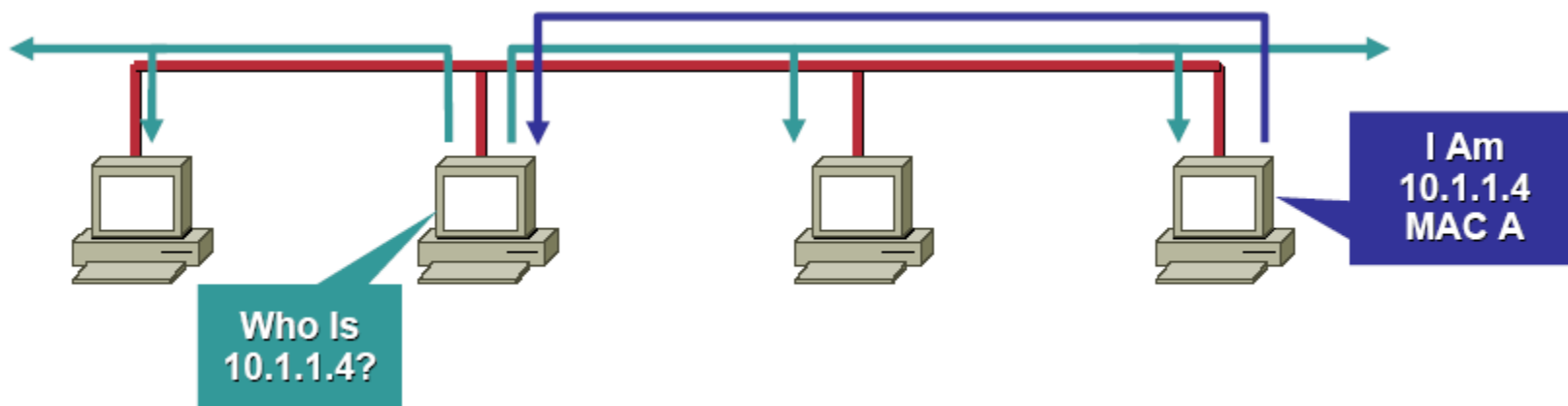


■ Mecanismul "DHCP Snooping"

- La activarea mecanismului, implicit, toate porturile unui switch sunt în starea "Untrusted"
- Se va configura starea "Trust" pe portul pe care se afla server-ul DHCP (eventual, pe portul de "uplink", dacă server-ul nu se află pe același switch)
- Switch-ul blochează mesajele "DHCP Reply" ce vin de pe porturile marcate "Untrusted"

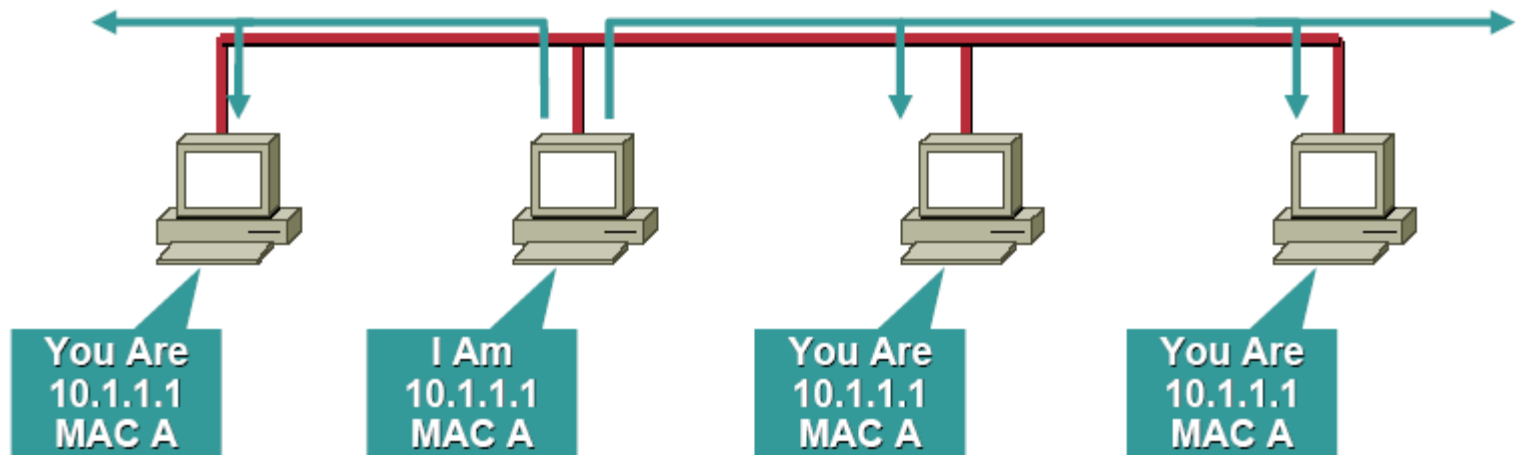
Protocolul ARP

- Înainte ca o stație să poată comunica cu altă stație din rețea, aceasta va transmite o cerere ARP, cu scopul de a afla adresa fizică (MAC) a stației destinație
- Cererea ARP este trimisă sub forma unui broadcast (la nivel 2)
- Toate stațiile din aceeași rețea vor recepționa și procesa cererea ARP; de răspuns, va răspunde doar stația care își va recunoaște adresa IP în conținutul cererii
- Răspunsurile ARP sunt menținute de kernel într-o tabelă (așa numitul “*cache ARP*”)



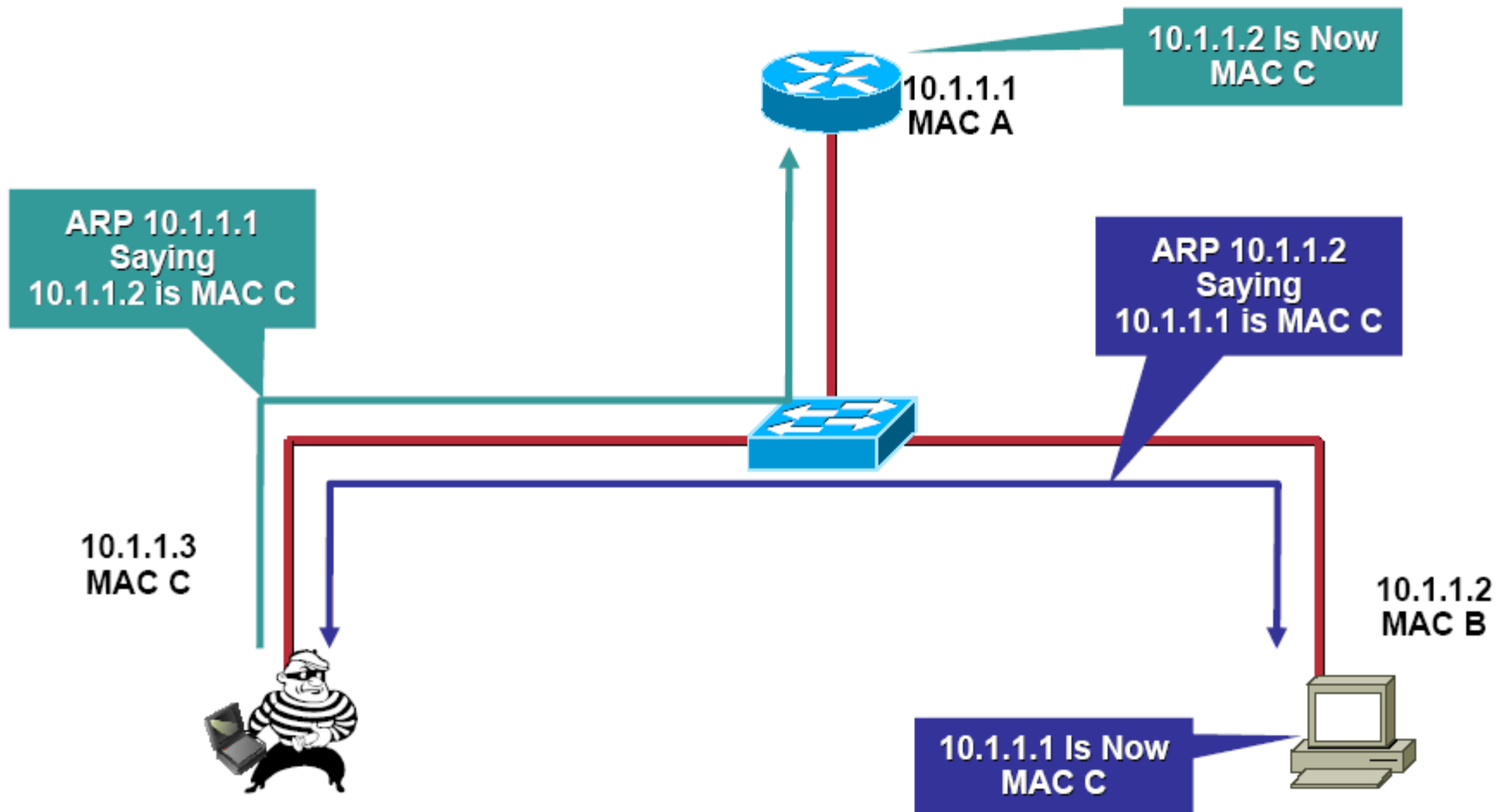
Protocolul ARP (cont.)

- În conformitate cu specificațiile protocolului ARP, unei stații îi este permis să transmită un răspuns ARP nesolicitat; celelalte stații din rețea vor memora această informație în cache-ul ARP propriu
- În acest mod, oricine poate pretinde că este proprietarul unei adrese IP/MAC
- Atacurile de tip “ARP Poisoning” folosesc această tehnică pentru redirectionarea traficului



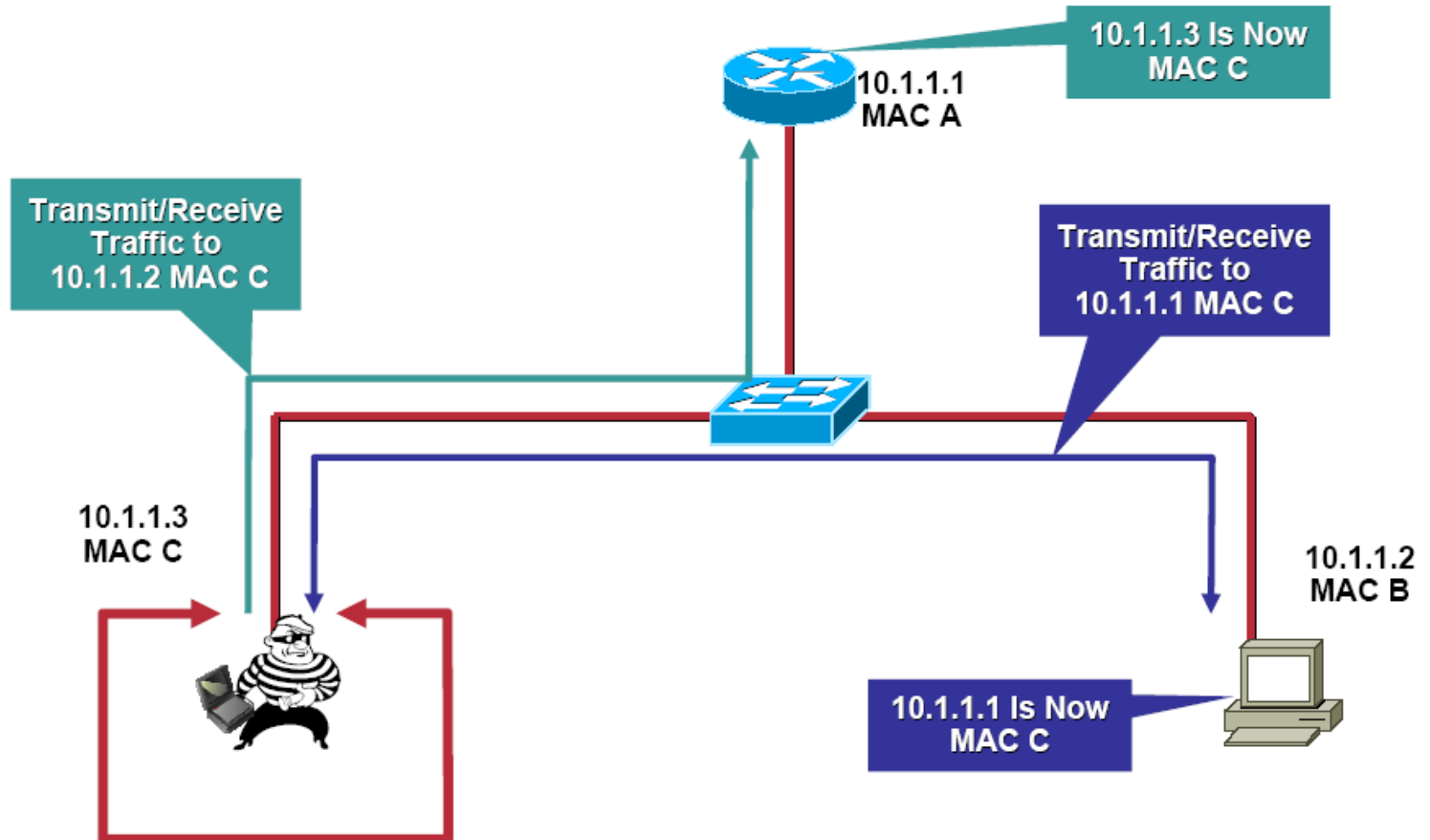
Atacul de tip ARP Poisoning

- **Atacatorul modifică tabelele ARP ale ruterului și PC-ului**



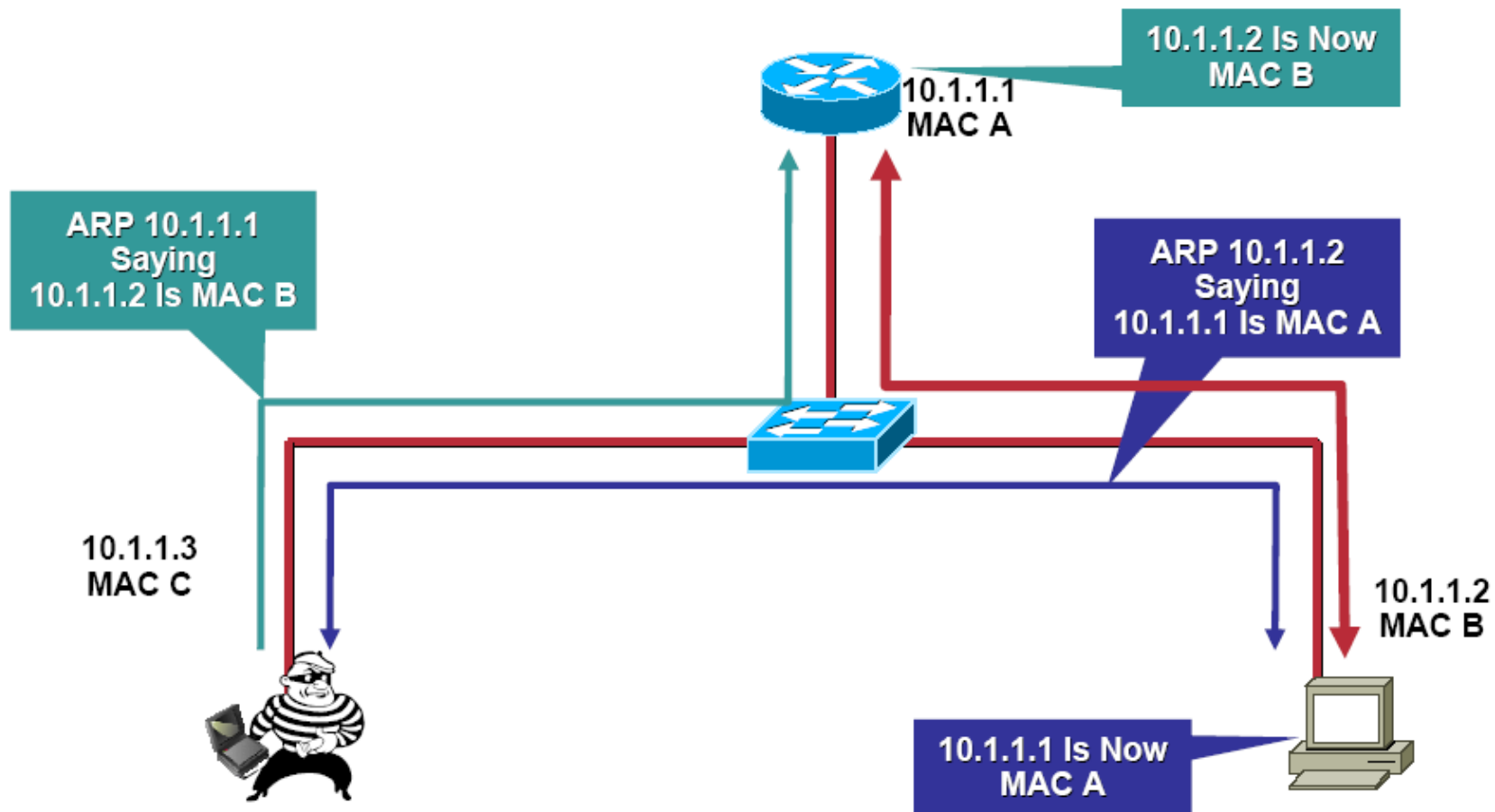
Atacul de tip ARP Poisoning (cont.)

- Tot traficul este astfel interceptat



Atacul de tip ARP Poisoning (cont.)

- În final, atacatorul corectează tabelele ARP
- Traficul revine la normal



ARP Poisoning - Unelte

- dsniff (<http://monkey.org/~dugsong/dsniff/>)
- Ettercap (<http://ettercap.sourceforge.net/>)
- Cain & Abel (<http://www.oxid.it/>)
- arpoison (<http://www.arpoison.net/>)

ARP Poisoning - Contramăsuri

- Crearea de intrări statice în tabelele ARP de pe stații
- Monitorizare rețea: arpwatch
- Dynamic ARP Inspection (Cisco)
- Secure-ARP (autentificare folosind certificate digitale)

